

Active Directory Attack & Defense Lab

A Hands-On Cybersecurity Project

Prepared by: **Piyush Kumar**

Brand: Quiet Hours

GitHub: github.com/takepiyush0987

LinkedIn: linkedin.com/in/piyush-kumar-929a8a405

Environment: Windows Server 2022 (Domain Controller) • Windows 11 (Domain Client) • Kali Linux
(Security Testing) • Oracle VirtualBox — Isolated Host-Only Network

Part A | Project Overview & Lab Setup

1. Project Objective

The objective of this project is to build an isolated Active Directory environment and understand how an enterprise Windows domain can be configured, enumerated, security-assessed, attacked in a controlled lab, monitored, hardened, and re-tested after security improvements.

Methodology

Identify/Understand → Enumerate → Assess → Simulate Attack → Detect → Remediate → Verify

2. Lab Architecture

The lab was created using Oracle VirtualBox on an isolated Host-only network.

Machine	Role	IP Address
DC01	Windows Server 2022 / Domain Controller	192.168.56.103
Client01	Windows 11 Domain Client	192.168.56.104
Kali Linux	Security Testing Machine	192.168.56.102

Network: 192.168.56.0/24 | **Domain:** cyberlab.local | **NetBIOS Domain:** CYBERLAB | **Domain Controller:** DC01.cyberlab.local

3. Active Directory Setup

3.1 Windows Server 2022

- Windows Server 2022 was installed and configured as the Domain Controller.
- The server was renamed to DC01.
- The server was configured with a static IP: 192.168.56.103.
- The server uses the VirtualBox Host-only network.

4. Installing Active Directory Domain Services

Active Directory Domain Services (AD DS) was installed from Server Manager.

Important options during domain controller promotion

- DNS Server: Enabled
- Global Catalog (GC): Enabled
- Read-Only Domain Controller (RODC): Disabled

A DNS delegation warning appeared during promotion. This was expected because this is an isolated lab with no authoritative parent DNS zone.

The domain was created as **cyberlab.local**, and the domain controller became **DC01.cyberlab.local**.

5. Active Directory Components

AD DS is Microsoft's directory service used to centrally manage users, computers, groups, authentication, authorization, policies, and organizational units.

Domain Controller

A Domain Controller stores and processes Active Directory information and provides services such as Kerberos authentication, LDAP directory services, DNS, Group Policy, and domain authentication.

6. Organizational Units (OU)

An OU is a logical container inside Active Directory. The lab contains an IT OU structure, e.g. OU=IT, DC=cyberlab, DC=local, with Users and Computers inside IT.

OUs are useful for

- Organizing users/computers
- Applying Group Policies
- Delegating administration

7. Users and Groups

- A test domain user was created: **testuser**.
- A custom security group was created: **IT-Admins**.
- testuser was added to CYBERLAB\IT-Admins.

Important observation: the name "IT-Admins" does not automatically mean the group has administrator privileges — its actual permissions must be verified.

8. Client01 Setup

- Windows 11 was installed as the domain client. Hostname: Client01, IP: 192.168.56.104
- Client01 was successfully joined to cyberlab.local.
- The user was able to log in as CYBERLAB\testuser.

9. Group Policy

- A group policy was created: **IT Client Policy**.
- The policy was linked/applied to the appropriate client OU.
- Group policy application was verified using: gpresult.
- An HTML report was auto-generated at C:\gpresult.html.

```
gpresult /h C:\gpresult.html
```

Conclusion: *The report confirmed the GPO was applied.*

Part B | Health Verification & Baseline Enumeration

10. Active Directory Health Verification

DC01 Health Check

```
dcdiag
```

Purpose: checks the health of Active Directory Domain Services and related components.

Conclusion: *The DC01 health check completed successfully.*

DNS Health Check

```
dcdiag /test:dns
```

Conclusion: *DNS test passed — the Active Directory DNS configuration was functioning.*

11. FSMO Role Verification

```
netdom query fsmo
```

The five FSMO roles were located on DC01.cyberlab.local:

- Schema Master
- Domain Naming Master
- RID Master
- PDC Emulator
- Infrastructure Master

12. Domain User Enumeration

```
net user /domain
```

This displayed domain user accounts. The lab contains standard AD accounts such as Administrator, Guest, krbtgt, and testuser. Computer accounts were also identified later through LDAP enumeration.

13. Domain Group Enumeration

```
net group /domain
```

This displayed domain groups. The Domain Admins group was also checked using:

```
net group "Domain Admins" /domain
```

14. Test User Verification

```
net user testuser /domain
```

Used to verify the domain account and its configuration.

15. Domain Discovery from Client01

Domain Controller Discovery

```
nlttest /dsgetdc:cyberlab.local
```

Conclusion: *Successfully discovered the Domain Controller — confirmed Client01 could locate DC01 through the domain.*

16. Secure Channel Verification

```
nltest /sc_query:cyberlab.local
```

Result: Status = 0, NERR_Success

Conclusion: Client01's secure channel with the domain was functioning correctly.

Important: this nltest sc_query result from Client01 is useful for checking the client-domain secure channel. A DC's own sc_verify check is not interpreted the same way as a domain member's secure-channel test.

17. DNS Resolution

```
nslookup DC01.cyberlab.local
```

Result: DC01.cyberlab.local resolved to 192.168.56.103. The DNS server display showed some reverse-DNS related behaviour, but forward resolution of the domain controller worked.

18. Connectivity Testing

Ping between Client01 and DC01 was successful, confirming basic network connectivity inside the Host-only lab network.

19. Domain Identity Verification

On Client01:

```
whoami
```

Result: cyberlab\testuser. Additional commands used:

```
echo %USERDOMAIN% echo %USERDNSDOMAIN%
```

Conclusion: These confirmed the domain identity of the logged-in user.

20. Active Directory Reconnaissance

After completing basic AD setup and security-health verification, security reconnaissance was started from Kali Linux.

Methodology used

Identify Service → Identify Version → Understand Service → Check Security Configuration → Determine Category → Continue Analysis

Part C | Network & Service Enumeration

21. Nmap Basic Scan

```
nmap 192.168.56.103
```

Important open ports identified

Port	Service
53	DNS
88	Kerberos
135	MSRPC
139	NetBIOS Session Service
389	LDAP
445	SMB
464	Kerberos Password Change
593	RPC over HTTP
636	LDAPS
3268	Global Catalog LDAP
3269	Global Catalog LDAPS
5985	WinRM

Conclusion: This port profile strongly indicates a Windows Active Directory Domain Controller.

22. Service Version Enumeration

```
nmap -sV 192.168.56.103
```

Service/version enumeration was performed to identify services. Nmap initially produced an incorrect identification for TCP/88 as "Apache Spark". This was treated as a possible false positive rather than immediately declaring a vulnerability. A more thorough scan was then performed.

23. Detailed Service Enumeration

```
nmap -sV --version-all -p 53,88,135,139,389,445,464,593,636,3268,3269,5985 192.168.56.103
```

Important results

- TCP/88 → Microsoft Windows Kerberos
- TCP/139 → Microsoft Windows NetBIOS
- TCP/389 → Microsoft Active Directory LDAP
- TCP/3268 → Microsoft Active Directory Global Catalog LDAP
- TCP/593 → Microsoft Active Directory Windows RPC over HTTP
- TCP/5985 → Microsoft HTTPAPI / WinRM-related service

The scan identified DC01's operating system family as Windows.

Important lesson: Nmap service detection is evidence, not absolute truth — a service/version result should be validated before using it to identify a vulnerability.

24. NetBIOS

NetBIOS (Network Basic Input/Output System) is an older Windows networking technology.

- UDP 137 → NetBIOS Name Service
- UDP 138 → NetBIOS Datagram Service
- TCP 139 → NetBIOS Session Service

Modern SMB commonly uses TCP/445. TCP 139 can still exist for legacy SMB/NetBIOS functionality. An open TCP 139 port alone does not mean the machine is vulnerable.

25. SMB Enumeration

```
smbclient -L //192.168.56.103 -N
```

Result: Anonymous login successful. However, share enumeration did not succeed through the SMB1 workgroup mechanism, and the system reported an SMB1-related failure. A second test forced SMB2:

- Anonymous session was accepted.
- No anonymous shares were listed.
- SMB1 was disabled.

Conclusion: Anonymous session acceptance does not automatically mean anonymous share access. No confirmed anonymous SMB share vulnerability was identified.

26. SMB Protocol Security

```
nmap -p 445 --script smb-protocols,smb-security-mode 192.168.56.103
```

Result: Supported SMB dialects

- SMB 2.0.2
- SMB 2.1
- SMB 3.0
- SMB 3.0.2
- SMB 3.1.1

SMB security result: message signing enabled and required.

Important security observations

- SMB1 disabled
- SMB2/SMB3 supported
- SMB signing enabled and required

Conclusion: No confirmed SMB security weakness was identified from these checks.

27. LDAP RootDSE Enumeration

```
nmap -p 389 --script ldap-rootdse 192.168.56.103
```

Important observations obtained

- Domain: cyberlab.local
- Domain naming context: DC=cyberlab, DC=local
- Domain Controller: DC01.cyberlab.local
- LDAP versions supported

- Global catalog ready
- Directory synchronized
- Schema naming context, Configuration naming context, Domain DNS naming context

RootDSE is a standard LDAP mechanism that exposes information about the LDAP server.

Conclusion: RootDSE information being available does not by itself indicate a vulnerability.

28. Anonymous LDAP Enumeration Test

```
ldapsearch -x -H ldap://192.168.56.103 -b "DC=cyberlab,DC=local" \ "(objectClass=user)"
SAMAccountName
```

Result: Operations error — "A successful bind must be completed before performing the operation."

Conclusion: Anonymous users could not enumerate actual AD user objects. This is a positive security observation.

29. Authenticated LDAP Enumeration

```
ldapsearch -x -H ldap://192.168.56.103 -D "testuser@cyberlab.local" -w [pw] \ -b
"DC=cyberlab,DC=local" "(objectClass=user)" SAMAccountName
```

Successful enumeration identified accounts including: Administrator, Guest, krbtgt, testuser, DC01\$, Client01\$. Result: 0 Success.

Conclusion: An authenticated domain user can perform normal directory enumeration — generally expected behaviour in Active Directory.

30. Test User Group Membership

```
ldapsearch ... "(&(objectClass=user)(SAMAccountName=testuser))" memberOf
```

Result: testuser is a member of CN=IT-Admins, OU=Users, OU=IT, DC=cyberlab, DC=local.

Important: being a member of IT-Admins does not automatically prove administrative privileges.

31. Members of IT-Admins

```
ldapsearch ... "(&(objectClass=group)(SAMAccountName=IT-Admins))" member
```

Result: IT-Admins contains testuser. Therefore, the custom group currently contains only testuser.

32. Group Nesting Check

```
ldapsearch ... "(&(objectClass=group)(SAMAccountName=IT-Admins))" memberOf
```

No memberOf value was returned for IT-Admins.

Conclusion: IT-Admins is not directly shown as a member of another group. This alone does not prove the group has no special permissions — privileges can also be granted through GPO, local group membership, ACLs, delegation, or other security configurations.

33. Effective Token Analysis

On Client01:

```
whoami /groups
```

Important results

- BUILTIN\Users
- CYBERLAB\IT-ADMINS
- Mandatory Label\Medium Mandatory Level

The following were **not** present: BUILTIN\Administrators, CYBERLAB\Domain Admins

Conclusion: *testuser is not a Local Administrator and is not a Domain Administrator, based on the effective token.*

34. Local Administrators Group

```
net localgroup Administrators
```

Client01 Administrators group contained: Administrator, CYBERLAB\Domain Admins, takep.

Important observation: CYBERLAB\IT-Admins was **not** present.

Conclusion: *testuser does not receive local administrator privileges through IT-Admins.*

35. Investigation of Local Account “takep”

```
net user takep
```

Important results

- Username: takep | Full name: Piyush Kumar
- Account active: Yes | Account expires: Never
- Password required: Yes | Password expires: No
- Last logon: Never
- Local group membership: Administrators, Users
- Global group membership: None

Conclusion: *takep is a local account on Client01 with local administrator privileges. The account has never logged on and its password is configured not to expire. Security classification: potential local administrator hardening issue — should be reviewed to confirm it is intentionally required.*

Part D | Password Policy, Kerberos, LDAP & SPN Enumeration

36. Domain Password Policy

Command on DC01:

```
net accounts
```

The values below reflect the observed lab configuration at the time of assessment, as returned by the command above — they are not necessarily the originally intended GPO design values.

Setting	Value
Minimum password age	1 day
Maximum password age	42 days
Minimum password length	7 characters
Password history	24
Lockout threshold	Never
Lockout duration	30 minutes
Lockout observation window	30 minutes

37. Password Policy Assessment

Positive settings

- Password history: 24 — prevents immediate reuse of many previous passwords.
- Maximum password age: 42 — enables password expiration.

Security weaknesses

- Minimum password length: 7 characters — weak compared with modern password-hardening practices.
- Lockout threshold: Never — no configured threshold after which repeated failed authentication attempts automatically trigger account lockout.

Potential risk: repeated authentication attempts may have less protection from account-lockout controls.

Conclusion: *Classified as a security-hardening finding, not treated as an automatically exploitable vulnerability.*

38. Service Principal Name (SPN) Enumeration

```
setspn -Q */*
```

SPNs were found for DC01 (standard domain controller SPNs including LDAP, DNS, GC, HOST, RPC, Kerberos-related services), krbtgt (standard: kadmin/changepw), and Client01 (standard: Host, RestrictedKrbHost).

Important: this message only means SPNs exist — it does not automatically mean a Kerberoasting vulnerability exists. No custom user/service account with an unusual SPN was identified in this enumeration.

Conclusion: *No custom Kerberoasting target was identified from the current SPN enumeration.*

39. Kerberos

Kerberos is the primary authentication protocol used by Active Directory. DC01 exposes TCP/88.

Basic Kerberos flow

User → KDC → Authentication Service (AS) → TGT → Ticket Granting Service (TGS) → Service Ticket → Target Service

Important components

- **KDC** (Key Distribution Center): provides Kerberos authentication and ticket services.
- **TGT** (Ticket Granting Ticket): evidence that the user has authenticated to the Kerberos system and allows the user to request service tickets.
- **TGS** (Ticket Granting Service): provides service tickets for specific network services.
- **SPN** (Service Principal Name): associates a service with an account in Active Directory.

40. Kerberoasting Concept

Kerberoasting is an Active Directory attack technique involving service accounts with SPNs. In a vulnerable configuration, an authenticated domain user can request a service ticket for a service associated with a user/service account, and the resulting ticket material may be subjected to offline password-cracking attempts.

Important: an SPN existing by itself does not mean Kerberoasting is possible — the key question is which account owns the SPN and how strong its password is.

***Conclusion:** Our current enumeration did not identify a custom service-account SPN.*

41. LDAP Signing Assessment

A broad LDAP Nmap query was attempted but failed due to an NSE argument-parsing issue ("failed to initialize the script engine"). This was a command syntax issue, not a DC01 service failure. A safer LDAP RootDSE enumeration was then performed successfully.

42. Active Directory Service Logs

```
Get-WinEvent -LogName "Directory Service" -MaxEvents 20
```

Important events observed

- Event 2886 — Warning
- Event 3041 — Warning
- Event 1220 — Warning

The most important event for the LDAP Signing assessment was **Event ID 2886**.

43. LDAP Signing Finding

Event 2886 reported that the security of the directory server could be significantly enhanced by configuring the server to reject:

- SASL LDAP binds that do not request signing.
- LDAP simple binds performed over a non-SSL/TLS connection.

The event also indicated that clients may currently be using such binds.

***Conclusion:** LDAP signing enforcement is not currently configured as required — a security-hardening finding. Potential risk: unsigned or clear-text LDAP authentication can increase exposure to credential*

interception or traffic manipulation when an attacker has an appropriate network position. This is a configuration weakness, not automatically a confirmed exploitable vulnerability.

44. LDAP Event 1220

Event 1220 reported that LDAP over SSL (LDAPS) would be unavailable at that time. This relates to the SSL/TLS certificate/configuration for LDAPS and should be treated separately from LDAP Signing.

45. RSOP Applied-Policy Investigation

```
Get-GPResultantSetOfPolicy -ReportType:Html -Path C:\RSOP.html
```

Result: RSOP Mode: Logging | Logging Computer: DC01 | Logging User: CYBERLAB\Administrator. An RSOP report was successfully generated (C:\RSOP.html).

A search for the exact phrase "LDAP Signing" did not return a match, so the Windows Directory Service event was used as the stronger evidence for the LDAP Signing assessment.

46. Current Security Findings Summary

Finding	Status	Classification
Anonymous LDAP user enumeration	Not identified	Secure configuration
Anonymous SMB share listing	Not identified	Secure configuration
SMB1	Disabled	Secure configuration
SMB signing	Enabled & required	Secure configuration
testuser Domain Admin	No	Secure / expected
testuser Local Admin	No	Secure / expected
Password minimum length = 7	Identified	Hardening finding
Lockout threshold = Never	Identified	Hardening finding
Custom Kerberoasting target	Not identified	No finding yet
LDAP signing enforcement	Not identified	Security hardening finding
LDAPS availability	Identified	Requires separate assessment

Part E | Lessons Learned & Security Controls Verification

Important Lessons Learned (from enumeration phase)

- **Open port ≠ vulnerability** — TCP/139 being open does not automatically mean SMB/NetBIOS is vulnerable.
- **Service detection can be wrong** — Nmap initially detected TCP/88 incorrectly as "Apache Spark"; always validate important findings.
- **Anonymous login ≠ anonymous access** — SMB retest: anonymous login successful, but no anonymous shares were exposed.
- **RootDSE exposure ≠ LDAP vulnerability** — LDAP RootDSE can expose standard server metadata; actual directory enumeration still required authentication.
- **Group name ≠ privilege** — "IT-Admins" sounds privileged, but actual effective permissions must be verified.
- **Effective token is important** — whoami /groups helps determine the groups actually present in the current security token.
- **Configured weakness ≠ confirmed exploit** — password policy and LDAP signing issues are findings, not automatically exploitable vulnerabilities.
- **Evidence comes before exploitation** — a proper assessment should establish what is configured → why it matters → whether it is enforced → whether it can be exploited → how to detect → how to fix.

Kerberos Username Enumeration

Status: Identified | Classification: Hardening finding. Kerberos username enumeration successfully identified valid domain principals such as administrator and testuser. No password or credential compromise occurred.

Account Lockout Threshold

Status: Identified | Classification: Hardening finding. Domain account lockout threshold is currently 0/not configured. No brute-force or account-lockout test was performed.

47. Security Controls Confirmed

- SMB signing is enabled and required.
- SMBv1 was not advertised.
- LM hash storage is disabled.
- Anonymous SID/Name translation is disabled.
- Password complexity is enabled.
- Clear-text password storage is disabled.
- Test user is not a Domain Admin.
- IT-Admins is not a privileged group.
- Test user cannot access Admin\$ or C\$.

***Conclusion:** The AD environment contains several effective security controls, although some hardening opportunities were identified.*

48. AD ACL & Permission Assessment

Domain Admins object

CYBERLAB\IT-Admins → Not present | CYBERLAB\testuser → Not present

Conclusion: No direct excessive permission for testuser or IT-Admins was identified on the Domain Admins object.

IT OU

CYBERLAB\IT-Admins → Not present | CYBERLAB\testuser → Not present

Conclusion: No direct excessive ACL permission was identified for testuser or IT-Admins on the IT OU.

49. Privilege-Path Assessment

- testuser → member of IT-Admins.
- IT-Admins was not found in Domain Admins, Enterprise Admins, or other privileged groups checked.
- DC01 local administrators: Administrator, CYBERLAB\Domain Admins, CYBERLAB\Enterprise Admins — CYBERLAB\IT-Admins is not present.

Conclusion: No direct privilege-escalation path from testuser through IT-Admins to DC01 administrative privileges was identified.

50. Administrative SMB Access Assessment

Admin\$ access: testuser authentication resulted in NT_STATUS_ACCESS_DENIED.

C\$ access: testuser authentication resulted in NT_STATUS_ACCESS_DENIED.

Conclusion: testuser does not have access to DC01 administrative SMB shares — secure/expected configuration.

51. SYSVOL & GPO Security Assessment

Authenticated testuser was able to read the SYSVOL share (sysvol\cyberlab.local). The structure identified: cyberlab.local → dfsrprivate, policies, scripts. GPO policy folders were identified using GUIDs; one GUID was mapped to Domain-Password-Policy. GPT.INI revealed the domain password policy values referenced in Section 36-37.

Conclusion: GPO security configuration is readable by an authenticated domain user through SYSVOL. No credentials or password hashes were obtained.

52. Net Logon Security Assessment

Authenticated testuser successfully accessed the NETLOGON share. NETLOGON root: no visible files or directories.

Conclusion: No sensitive logon script or file exposure was identified.

53. LDAP Security Assessment

Anonymous LDAP

Basic naming-content information was disclosed anonymously.

Authenticated LDAP

testuser was able to enumerate basic directory objects and attributes such as sAMAccountName, cn, description, userAccountControl. Returned objects included Administrator, Guest, krbtgt, DC01\$, testuser and Client01\$.

Conclusion: Normal authenticated directory-read access was confirmed. No credentials, password hashes or secrets were obtained.

54. NTLM/SMB Authentication Security Assessment

SMB security configuration: EnableSecuritySignature = True, RequireSecuritySignature = True.

Conclusion: SMB signing is enabled and required, providing protection against certain SMB relay/MITM attack paths.

LAN Manager Authentication Level

The exact LmCompatibilityLevel value was not explicitly confirmed from the checked configuration. No assumption was made that the configuration is weak or strong without evidence.

55. Windows Security Policy Hardening

“Do not store LAN Manager hash value on next password change” — Enabled ✓

Part F | Attack Simulation – Overall Result

56. Attack Simulation Summary

Controlled attack simulations were performed against the isolated AD lab.

Successful security observations

- Kerberos username enumeration.
- Anonymous LDAP naming-content disclosure.
- Authenticated LDAP enumeration.
- Authenticated SYSVOL enumeration.

Blocked / protected paths

- SMB administrative access to Admin\$ — Access Denied.
- SMB administrative access to C\$ — Access Denied.
- testuser → Domain Admins — no direct path.
- IT-Admins → DC01 Administrators — not present.
- Direct testuser/IT-Admins ACL on checked privileged objects — not identified.

Credential compromise: None.

57. Important Security Lessons Learned

- **Open port ≠ vulnerability** — an open TCP port only indicates that a service is reachable, not that it is vulnerable.
- **Anonymous login ≠ anonymous sensitive access** — a service may allow limited anonymous information disclosure without exposing sensitive data.
- **Group name ≠ privilege** — a group named IT-Admins is not automatically privileged; actual effective permissions must be verified.
- **Effective access matters** — AD security should be evaluated using the permissions actually assigned to the user/group, not only the group name.
- **GPO setup security** — GPO metadata and policy files must be protected because they can reveal important security configuration.
- **No vulnerability → don't create one** — if a weakness is not naturally present, the environment should not be modified just to demonstrate an attack.

SPN Security Audit — Summary Note

An SPN security audit is the process of identifying and reviewing Service Principal Names (SPNs) in an Active Directory environment to understand which accounts are associated with network services and whether they create Kerberos-related security risks. During an SPN security audit we enumerate accounts, identify service accounts, review their configuration, and check for risks such as Kerberoasting exposure — the goal is to detect and reduce unnecessary or risky SPN configurations.

In this Active Directory lab, user accounts and their SPNs were enumerated; a user SPN associated with a web service account (HTTP/webservice.cyberlab.local) was identified, and Impacket's GetUserSPNs was used to investigate a Kerberos KRB_AP_ERR_SKEW error, which helped illustrate the importance of time synchronization in Kerberos authentication.

Part G | Delegation, SPN Investigation & Privilege Analysis

60. Active Directory Delegation Reconnaissance

AD accounts/computers were checked for delegation-related settings. "Trusted For Delegation" was used to identify which computer is trusted for Kerberos delegation.

- DC01 = TrustedForDelegation = True
- Client01 = TrustedForDelegation = False

***Conclusion:** DC01 is delegation-enabled, while Client01 is not trusted for delegation.*

61. User Account Delegation Check

Delegation-related attributes were verified for testuser and Administrator account properties. "Account Not Delegated" and related delegation settings were assessed to identify whether sensitive accounts are protected against Kerberos delegation abuse.

62. Service Account / SPN Investigation

```
Get-ADUser -Filter * -Properties ServicePrincipalName
```

An HTTP SPN was found on the webservice account: **HTTP/webservice.cyberlab.local**, confirming the web service account is configured as a registered network service identity. SPN-based Kerberos authentication and Kerberoasting exposure were investigated in the lab.

63. Impacket GetUserSPNs Enumeration

```
GetUserSPNs.py cyberlab.local/testuser -dc-ip 192.168.56.103
```

SPN enumeration was performed from Kali in the context of a domain user. The webservice account's SPN/password-last-set information was enumerated. During a ticket-request attempt, a **KRB_AP_ERR_SKEW** error occurred — identified as a Kerberos client/DC time-synchronization mismatch.

64. Kerberos Time Synchronization Troubleshooting

Client/DC time synchronization was investigated for Kerberos authentication. DC01's time source was the local CMOS clock. The displayed time (UTC) on Kali and DC01 was compared, and KRB_AP_ERR_SKEW was identified as a Kerberos clock-skew issue.

***Conclusion:** Time synchronization is critical in Kerberos authentication.*

65. Administrator Account Security Assessment

The domain Administrator account's properties were verified: account-enabled status, password-last-set information, last-logon information, and SPN presence. No unexpected SPN presence was found for the Administrator account.

***Conclusion:** This check reviewed the privileged account's authentication/delegation exposure.*

SPN Security Audit — Detail

SPN security audit is the process of identifying and reviewing Service Principal Names (SPNs) in an Active Directory environment to understand which accounts are associated with network services and whether they create Kerberos-related security risks. During the audit, SPNs were enumerated, service accounts identified,

their configuration reviewed, and risks such as Kerberoasting exposure checked, with the goal of detecting and reducing unnecessary or risky SPN configurations.

Note: an SPN security audit means auditing service accounts and their SPNs in Active Directory to identify unnecessary SPNs and Kerberos-related security risks such as Kerberoasting.

66. AdminSDHolder & Protected Accounts

Objective: assess the security and ACL inheritance of AdminSDHolder-protected/admin accounts.

Key checks

- AdminSDHolder protected object: CN=AdminSDHolder, CN=System, DC=cyberlab, DC=local
- Admin Count = 1 identified on Administrator and krbtgt accounts.
- Administrator's ACL-inheritance protection was checked.

Findings

- Administrator's "Access Rules Protected" = True.
- AdminSDHolder's owner is CYBERLAB\Domain Admins.
- AdminSDHolder grants privileged groups permissions including Generic All, Write DACL, Write Owner.

Security impact: AdminSDHolder is important for maintaining permissions on privileged/protected accounts. Improper permissions here can create privilege-escalation paths.

***Conclusion:** The AdminSDHolder and protected-account ACL structure was successfully assessed.*

67. AD ACL / Permission Abuse Assessment

Objective: identify excessive permissions for testuser and related AD objects.

ACL entries/permissions assigned on the TestUser AD object

*Note: the principals listed below represent ACL entries (ACEs) found on the TestUser object's access control list — i.e. which principals hold which permissions **on** the testuser object. They do not represent testuser's own group memberships or effective privileges.*

- System — Generic All
- Account Operators — Generic All
- Domain Admins — Generic All
- Enterprise Admins — Generic All
- Builtin\Administrators — Generic All / Write DACL / Write Owner

The Account Operators group membership was checked and found **empty**; the Account Operators ACE on the TestUser object was direct/non-inherited.

Security impact: Generic All, Write DACL and Write Owner permissions can provide powerful control. An empty privileged group meant this permission path was currently dormant.

***Conclusion:** AD ACL permissions were successfully assessed and potential privilege paths identified.*

68. Machine Account Quota Assessment

Objective: check the quota allowed for domain users to create new computer accounts.

Finding: ms-DS-MachineAccountQuota = 10.

***Conclusion:** Excessive/unused machine-account-creation allowance can be relevant to certain AD attack paths.*

69. LAPS Security Assessment

Objective: check whether Windows LAPS-related schema attributes are available/configured.

Checks

- AD schema object version checked.
- LAPS-related attributes such as ms-LAPS/AdmPwd searched for.

Finding: LAPS-related attributes were not returned in the search.

Important: schema object version alone does not prove LAPS deployment.

Conclusion: *LAPS deployment was not confirmed in the lab.*

70. Active Directory Certificate Services (AD CS) Assessment

Objective: check whether AD CS is installed/configured.

Finding: AD CS-related Windows features were not found installed/configured.

Conclusion: *An AD CS-based attack surface was not present/configured in this lab.*

Part H | Audit Policy, DNS & LDAP Channel-Binding Assessment

71. Advanced Audit Policy Assessment

Objective: assess the Domain Controller's security-auditing configuration.

Initial assessment

Multiple Windows audit categories were checked. Auditing was enabled for: Logon, Account Lockout, Special Logon, Audit Policy Change, Authentication Policy Change, Computer Account Management, Security Group Management, User Account Management, Directory Service Access, Kerberos Service Ticket Operations, Kerberos Authentication Service, and Credential Validation. Some areas — such as Process Creation and Detailed File Share — had no auditing.

Defensive configuration applied

A GPO named **AD-Audit-Policy** was created/linked, configuring “Audit Directory Service Changes” → Success → Failure.

Validation

```
gpupdate /force
```

Conclusion: “Directory Service Changes = Success and Failure” was verified and successfully configured.

72. LDAP Channel Binding Assessment

Objective: assess the LDAP Channel Binding configuration.

Finding: the LDAP Enforce Channel Binding registry configuration was not explicitly present.

Important: LDAP Signing and LDAP Channel Binding are separate security protocols — LDAP signing was assessed separately earlier (Sections 41-45).

Conclusion: Explicit Channel Binding configuration was not present in the lab; no hardening change was confirmed.

73. DNS Zone Security Assessment

Objective: check the security and dynamic-update configuration of AD DNS zones.

Findings

- cyberlab.local — Primary, AD-integrated, Secure dynamic updates.
- _msdcs.cyberlab.local — Primary, AD-integrated, Secure dynamic updates.
- Reverse zones — Primary, not AD-integrated, secure dynamic update status not applicable.

Conclusion: The main AD DNS zones were configured with secure dynamic updates.

74. DNS Recursion Assessment

Objective: check the DNS Recursion configuration.

Finding: Enable = True. The SecureResponses field was not explicitly configured.

Important: recursion being enabled does not automatically prove a vulnerability — it must be assessed in the context of exposure and the DNS server's intended role.

Conclusion: *DNS Recursion was enabled; no configuration change was made.*

Part I | Account Hygiene & Service Account Security

75. Inactive Account Audit

Objective: identify long-term inactive user accounts.

Finding: in a 90-day inactivity search — Guest (Disabled), krbtgt (Disabled), webservice (Enabled, LastLogonDate blank).

Important: a blank LastLogonDate does not automatically prove an account is unused. Since the webservice account had an HTTP SPN, it was not blindly disabled.

Conclusion: *The inactive-account assessment was completed; webservice was investigated on the basis of its context.*

76. Web Service Service-Account Security

Objective: assess the security of the HTTP-SPN service account.

Findings

- Account enabled.
- Password never expires = False.
- Password expiry applicable; Password Last Set available.
- Account Not Delegated = False.
- SPN = HTTP/webservice.cyberlab.local

Security impact: HTTP service accounts are important for Kerberos/SPN-related security assessment. “Account Not Delegated = False” was not automatically treated as a vulnerability.

Conclusion: *The web service account was successfully assessed.*

77. Service Account Interactive Logon Audit

Objective: check whether the web service account has interactive/RDP logon rights.

Findings

- No direct group membership; principal group membership: Domain Users.
- Interactive logon rights included mainly the built-in Administrative group (“Remote Interactive Logon: Built-in Administrators”).

Conclusion: *webservice did not receive broad interactive/RDP access; no obvious RDP exposure was identified.*

78. Controlled Privilege-Path Validation

Objective: safely validate the previously identified ACL privilege path.

Validation: Account Operators group membership was checked and found **empty**. testuser had Generic All on Account Operators, but the group had no members.

Conclusion: *This was a dormant privilege path; active exploitation was not performed.*

Part J | Detection, Logging & Forensic Analysis

79. Process Creation Audit Assessment

Objective: check the current effective state of process-creation auditing.

Finding (at the time of this assessment): the audit-policy review showed Process Creation = No Auditing.

Note on chronology: at this stage of the assessment, no Event ID 4688 entries had yet been observed in the security log. This was not treated as proof of the effective audit policy by itself. Later in the project, an Event ID 4688 ("A new process has been created") event was in fact observed in the security log — see later log-review activity. The two observations are recorded here in their original chronological order rather than reconciled, since the project notes do not document an explanation for the change between the two points.

Conclusion: *At the point of this audit-policy check, process-creation auditing appeared not to be enabled; this finding should be read alongside the later observed Event ID 4688 evidence rather than in isolation.*

80. User Account Management Audit Assessment

Objective: assess user-account-management auditing configuration.

Finding: User Account Management = No Auditing. The AD-Audit-Policy GPO did not include user account management or process-creation configuration.

Conclusion: *User account management auditing was not currently enabled.*

81. Directory Service Changes Detection Validation

Objective: validate directory-service-changes auditing via a controlled AD modification.

Test: testuser's description attribute was changed in a controlled manner ("AD-Audit-Test", later "AD-Audit-Test2").

Findings

- Directory Service Changes audit policy = Success and Failure.
- Inherited auditing entries were present for testuser.
- The expected Event ID 5136 was not successfully observed in the security log.

Conclusion: *The policy configuration was successfully verified, but 5136 detection was not successfully validated; further troubleshooting was intentionally stopped.*

82. Account Lockout Security Assessment

Objective: assess account-lockout policy and auditing.

Finding: Account Lockout = No Auditing. Domain password policy: Lockout threshold = 0, Lockout duration = 30 minutes, Lockout observation window = 30 minutes.

Security impact: a lockout threshold of 0 means account lockout is effectively disabled — repeated authentication failures will not automatically trigger a lockout.

Conclusion: *Security gaps were identified in both account-lockout configuration and auditing; no policy change was made.*

83. Credential Validation Audit Assessment

Objective: check credential-validation auditing.

Finding: Credential Validation Auditing = No Auditing.

Security impact: dedicated audit visibility of credential-validation activity is limited.

***Conclusion:** Credential validation auditing was not enabled.*

84. Controlled Authentication-Failure Simulation

Objective: generate a controlled failed authentication to validate detection.

Test: an incorrect password was used with testuser to generate a controlled authentication failure.

```
runas /user:cyberlab\testuser cmd → Result: RUNAS ERROR 1326
```

Detection

Event ID 4625 was identified in the security log.

***Conclusion:** Controlled failed authentication was successfully generated and detected.*

85. Event 4625 Forensic Analysis

Objective: analyze the forensic fields of a failed-logon event.

Event: Event ID 4625 — “An account failed to log on.”

Important fields observed

- Account Name, Logon Type, Failure Reason, Status, Sub Status
- Process Information, Workstation, Source Network Address, Authentication Package

Examples: 0xC000006D → bad/invalid authentication | 0xC000006A → bad password

***Conclusion:** Event 4625 contains detailed authentication evidence.*

86. Failed Authentication Event Identification

Objective: match the controlled testuser authentication failure against existing 4625 events.

Finding: direct text matching for “testuser” did not identify the expected event.

Important: this does not conclude that authentication was not logged — only that the selected filtering method did not identify the exact event.

***Conclusion:** Filtering was not unnecessarily extended further.*

87. Logon Type Analysis

Objective: identify different logon types present in 4625 events.

Observed

- Logon Type 2 → Interactive
- Logon Type 3 → Network
- Logon Type 7 → Unlock

***Conclusion:** Security events provide different authentication/logon context that is useful for forensic analysis.*

88. Successful Authentication Detection

Objective: compare successful authentication events against failed authentication events.

Finding: in the security log — Event ID 4624 → Successful logon; Event ID 4625 → Failed logon.

***Conclusion:** Both successful and failed authentication events are observable in the lab. Authentication monitoring/detection validation was successfully completed.*

89. Privileged Group Membership Change Detection

Objective: assess the availability of security-group-management auditing.

Finding: Security Group Management = No Auditing.

Security impact

- AD security-group membership changes currently have no detailed auditing visibility enabled.
- Unauthorized privileged-group membership changes may be difficult to detect.

***Conclusion:** A security-group management auditing gap was identified.*

Final Summary & Conclusion

Overall Project Conclusion

This project built and assessed an isolated Active Directory lab environment end-to-end — from domain setup and baseline health verification, through network/service enumeration, Kerberos and LDAP analysis, ACL and delegation review, to controlled attack simulation and audit-policy/log-based detection. The methodology consistently emphasized separating *configuration observations* from *confirmed, exploitable vulnerabilities* — validating every finding with evidence before drawing conclusions.

Key Takeaways

- An open port, a broad group name, or an existing SPN is only a starting point for investigation, not proof of a vulnerability.
- Effective permissions (via tools like *whoami /groups* and ACL checks) matter far more than group names or assumptions.
- Several strong security controls were already in place in this lab: SMB signing required, SMBv1 disabled, LM hash storage disabled, and no direct privilege-escalation path from the test user to Domain Admin.
- Several hardening gaps were identified and documented: weak minimum password length, no account lockout threshold, LDAP signing not enforced, and multiple audit categories (process creation, account management, security group management, credential validation) left unaudited.
- Detection engineering (audit policy configuration, Event IDs 4624/4625/5136/2886) was used to validate whether security-relevant activity is actually observable in logs — not just whether a control exists on paper.